This page has been automatically translated. Please refer to the page in French if needed.

Personal Data Protection Obligations (GDPR)

Verified 26 April 2024 - Directorate for Legal and Administrative Information (Prime Minister)

Any company that performs data processing (payroll management, recruitment, customer or supplier records, etc.) must comply with the **General Data Protection Regulation (GDPR)**. It shall apply to **any company**, **regardless of size or industry**, where it is established in the territory of theEuropean Union or its activity directly targets European residents.

Processing of personal data: definition

It is necessary to define **personal data** to understand what the **processing of personal data**.

What is personal data?

Personal data or " *personal data* is a **information relating to an identified or identifiable natural person** (e.g. name, first name, social security number, address, phone number, email address, photo, fingerprint, geolocation data, IP address or online identifier).

A person is said **identified** when you know your identity. A person is **identifiable** when it can be identified, even if its name and surname would remain unknown, from **data set crossing** (e.g. a woman living at such an address, born such a day and a member of such an association).

> **Please note**
>
> It doesn't matter if the information is **public or confidential** and **whatever the medium** on which the information is located (paper form, USB stick, hard drive, camera, etc.).

On the other hand, data is no longer personal when it is **anonymised**, thus eliminating any possibility of identifying the data subject.

Similarly, a data item is not personal when it relates to a **legal person** (e.g. company, association).

Example :

The postal address, telephone number of the switchboard or a generic email address (e.g.: " *company1[@]email.fr* ") of a company are not personal data.

What is personal data processing?

A processing of personal data consists of **any transaction involving personal data**, irrespective of the process used (e.g. collection, recording, storage, modification, consultation, dissemination or erasure of data).

In other words, data processing occurs whenever a person's data is used in some way, regardless of who owns the data (a **customer**, one **supplier**, one **provider**, one **employee**, one **applicant for employment**, etc.).

Processing of personal data is not necessarily computerized, **paper files are also affected** and must be protected under the same conditions.

Example :

- Create a customer or supplier file (paper or computerized)
- View an Excel table containing human resources data (pay slips, employment contracts, CVs and cover letters...)
- Commercial prospecting by mail or email
- Delivery of an order

- Preserving IP addresses
- Video surveillance recording in a store
- Destruction of paper documents containing personal data.

> **FYI**
>
> In general, **as soon as a company employs staff**, the human resources departments are required to process employee data (payroll management, recruitment, employment contracts, etc.) and are therefore **systematically covered by the GDPR**.

In order to comply with the GDPR, data processing must comply with the **following principles** :

- Treatment should be **lawful** : it must be based on one of the six legal bases laid down by the GDPR, in particular the consent of the data subject, the performance of a contract or the fulfillment of a legal obligation.
- Treatment should be **transparent** : the person whose data is collected must be informed of the collection and its purpose, as well as the rights that he has over his data (access, rectification, portability, erasure...).
- Treatment should have a **purpose** : the controller must define the purpose of the data collection (e.g. prospecting, customer relations monitoring, human resources). The data must not be processed in a manner incompatible with that purpose.
- Treatment should be **proportional and relevant** : only data strictly necessary for the achievement of the objective may be collected. We talk about " *minimization principle* ". For example, a business does not have to collect the phone number of its customers when it only sends email prospecting.
- Treatment should be **temporary** : the retention period of the information must be defined as soon as the data collection device is in place. Once the objective is achieved, the information collected is no longer necessary and should therefore be deleted.
- Treatment should be **secure** : all necessary measures to ensure security, including the confidentiality of personal data, must be put in place (e.g. passwords, https, backup). These security measures are proportional to the risks involved (e.g. theft or loss of data).

Except in exceptional cases, any processing of so-called data **sensitive** is **forbidden**. This is a **category of highly personal data** which are likely to lead to discrimination if revealed (e.g. racial or ethnic origin, political opinions, religious or philosophical beliefs, sexual orientation, trade union membership, genetic data).

Who is responsible for the processing?

The legal representative of the company (head of company, manager, president...) is designated " **controller** ". The controller is the individual **on the initiative of data processing**, it shall determine its aims and means.

Most often, the data controller uses a **subcontractor** responsible for processing the data on behalf of the controller (e.g. data hosting, IT maintenance, marketing message sending service).

The controller and its processor must comply with **numerous obligations** on the protection of personal data.

Inform the persons concerned

The controller shall **to inform any person** whose data is collected.

This obligation applies whether the collection is **straightforward** (e.g. data collected from the person in a form) or **indirect** (e.g. data retrieved from business partners, data brokers or publicly available sources).

The information must be provided **at the time of collection** (in the case of direct collection) or within a reasonable time after obtaining the data, but not exceeding **1 month** (in the case of indirect collection).

What information should be provided?

The controller shall transmit the **following information** :

- Identity and contact details of the controller
- Contact details of the Data Protection Officer (DPO), if applicable
- Purpose of the processing: i.e. what the personal data collected will be used for
- Legal basis for processing: this may be the consent of the person, compliance with a legal obligation, performance of a contract, etc.
- Compulsory or optional provision of personal data: the consequences for the person in case of non-provision of the data
- Recipients of personal data: who will receive and access the data (competent internal service, provider, etc.)
- Retention period for personal data
- Rights of the individual in his data: right to refuse collection, right to access, rectify and erase his data
- Right of the person to lodge a complaint with the Cnil
- Source from which personal data originate, in the case of indirect collection
- Existence of a transfer of personal data to a country outside the EUEuropean Union, if applicable.

How to deliver information?

The information must be transmitted in a **concise, transparent, understandable and easily accessible**, in clear and simple terms. In other words, the information must be presented in an effective and succinct way to **not drowning** among other informative content.

Example :

A company does not comply with the requirement of accessibility of information when it has multiple pages to consult, links within the different pages and redundancy of information.

The form of presentation must **consider support** on which the information is communicated. For example, in order to avoid too long entries in an online form, the controller may provide a first level of information at the end of the form and refer to a dedicated page on his website.

The title of the page should be clear, for example: " *privacy policy* ", " *privacy page* ' or ' *personal data* ". This page is part of the mandatory information on a website (https://entreprendre.service-public.gouv.fr/vosdroits/F31228?lang=en) .

> **Please note**
>
> The Cnil offers numerous examples of information (https://www.cnil.fr/fr/rgpd-exemples-de-mentions-dinformation) applicable according to the situation (e.g. online sales, commercial prospecting, video surveillance at the workplace, access to business premises by badge).

What is the penalty for not providing information?

Failure to inform the person from whom the data are collected shall be punishable by **criminal fine** of **€1,500** for individual entrepreneurs and **€7,500** for businesses.

Obtain consent of the persons concerned

The **consent** corresponds to any expression of will by which the data subject accepts, by a declaration or by a clear positive act, that personal data concerning him or her are being processed.

In most cases, the controller should **to obtain consent** the person before processing his or her personal data.

Is consent still required?

The collection of consent shall be **obligatory**, unless the treatment is justified by **performance of a contract** (e.g. contract of employment, contract of sale, lease).

In addition, the consent package is **always obligatory** in the following cases:

- Collecting **'sensitive' personal data**. This is a category of highly personal data which may lead to discrimination if revealed (e.g. racial or ethnic origin, political opinions, religious or philosophical beliefs, sexual orientation, trade union membership, genetic data).
- Reuse of data for **other purposes**. For example, a sports shop organizes a contest and collects data from participants to contact the winner (initial purpose). If the store subsequently decides to use this data to create a customer file (new purpose), it will again have to obtain the consent of the individuals.
- Using **non-essential cookies** the operation of the service (e.g. advertising targeting). The Cnil has compiled a file on rules applicable to the use of cookies (https://www.cnil.fr/fr/site-web-cookies-et-autres-traceurs) .
- Use of data for the purpose of **commercial prospecting** by electronic means (e.g. newsletter, sms). The consent obligation expires if the person being prospected is already a client of the company and the prospecting concerns similar products or services.

How do I collect meaningful consent?

To be valid, the consent obtained must complete the **4 following conditions** :

- Consent must be **free** : it must not be coerced or influenced. The data subject must have a genuine choice to accept or refuse the processing, without having to suffer negative consequences in case of refusal (e.g. inaccessibility of the website). The person must also have the right to withdraw consent at any time, and as easily as he or she has given it.
- Consent must be **enlightened** : before giving consent, the data subject must have received sufficient information (identity of the controller, purpose of the processing, type of data collected, right to withdraw consent and possible transfer of data outside the EU) so that he or she can make an informed decision. Information must be communicated in clear and easily understandable terms.

- Consent must be **specific** : if the processing involves several purposes (e.g. customer management, satisfaction survey, prospecting), the data subject must be able to give his or her consent independently for one or other of these purposes.
- Consent must be **unambiguous** : it must be given by a deliberate act, without any ambiguity. It may be collected, for example, by means of a written or oral statement or by ticking a box electronically (e.g.: " *I agree that my e-mail address will be re-used for e-mail marketing purposes* ".

By contrast, the use of default ticked consent boxes is **forbidden**. In addition, the silence of the data subject (e.g. the person visits the website without accepting or refusing cookies) **does not constitute consent**.

> **Please note**
>
> The controller must be able to demonstrate that the data subject has given his or her free, informed, specific and unambiguous consent.

How does withdrawal of consent work?

The data subject must also have the **right to withdraw consent** at any time, and as easily as she gave it. For example, where consent is obtained electronically only by clicking, typing or scanning the screen, the data subject should be able to withdraw that consent in the same way.

Example :

Forcing the individual to follow a complex path through links to electronic documents or requiring the individual to enter a password does not meet the requirement to be able to withdraw consent as simply as it was given.

Where a data subject withdraws his or her consent, the controller must cease all processing operations based on that consent. However, transactions carried out on the basis of a valid consent given before withdrawal shall remain valid.

What is the penalty for not giving consent?

Where the collection of consent is mandatory, the processing of personal data obtained **without consent** of the person concerned shall be punishable by **5 years** imprisonment and **€300,000** fines for individual contractors and **€1,500 000** for businesses.

Guaranteeing the rights of data subjects

The controller shall **to guarantee rights** to the persons whose data are collected: right of access, right of rectification, right of erasure, right to data portability and the right to object to processing.

Right of access to data

The controller must allow the person who requests it, **to access its data** subject to treatment. The data subject must be able to exercise this right, for example, by means of an online form, an email or a contact email.

On this occasion, the responsible person must provide the **following information** :

- Purpose of the processing: i.e. what the personal data collected will be used for
- Recipients of personal data: who will receive and access the data (competent internal service, provider, etc.)
- Retention period for personal data
- Rights of the person in his data: right to refuse processing, right to rectify and erase his data
- Right of the person to lodge a complaint with the Cnil
- Source from which personal data originate, in the case of indirect collection
- Existence of a transfer of personal data to a country outside the EUEuropean Union, if applicable.

The data subject must be able to access the information on which the controller has relied **to take a decision concerning it**. For example, the elements that would have been used by an employer not to give him a promotion or the score assigned by a bank that led to the rejection of a credit application.

The manager has **1 month to respond** from the date of receipt of the request, including if the controller does not have any data on the person exercising his right of access.

The information must be provided **for free** and in **easily understandable**. The codes, acronyms and abbreviations used should be explained (possibly in a lexicon).

Example :

The code " *Segmentation: A+* may mean that the data subject is considered a VIP customer.

The controller may **deny access request** on condition that it gives reasons for its decision. In this case, it must inform the applicant of the means and time limits for challenging it.

It can also **failing to respond to manifestly abusive requests** in particular because of their number and their repetitive or systematic nature (e.g. request for a full copy of a recording every week).

Right to rectification of data

The controller must allow the person who requests it to **rectify inaccurate data** as soon as possible. The data subject must be able to complete his or her incomplete data, including by providing a supplementary declaration.

Right to erasure of data (“right to be forgotten”)

The controller shall allow the person who so requests to obtain **the erasure of its data** as soon as possible.

This "right to be forgotten" is not general, it applies **only in the following cases** :

- Personal data are no longer necessary for the purposes for which they were collected or otherwise processed.
- The data subject withdraws the consent on which the processing is based, and this processing is not justified by the performance of a contract (e.g. sales, rental, employment).
- The data subject objects to the processing and there are no legitimate grounds for the processing.
- Personal data has been unlawfully processed (e.g. the consent of the person was not collected when it was mandatory)
- Personal data must be erased in order to comply with a legal obligation under EU lawEU or by the law of the Member State to which the controller is subject.

Right to data portability

The controller must allow the person who requests it, **receive and reuse data**within a reasonable period (between 1 and 3 months depending on the complexity of the application).

The right to portability applies to personal data **declared by the person** (e.g. e-mail address, name, age) and to **generated by its activity** when using a service or device (e.g. purchases on a loyalty card).

On the other hand, personal data which are **derived, calculated or deducted** on the basis of the data provided by the data subject (e.g. profiling for advertising purposes) do not fall within the scope of this right.

> **Please note**
>
> Moreover, this right only concerns data processed by automated means, which excludes data stored in paper format.

Manager must communicate **for free** data in a **structured, commonly used and computer-readable format**. Where technically possible, the data subject may request that his or her data be directly transmitted to another controller.

This right shall not result in the deletion of the data of the service from which they are transferred. In addition, it can be exercised at any time, including if the person wants to continue using the service after exercising that right.

Example :

The right to portability can be exercised in many situations, for example:

- On-demand music or video services (e.g. playlists, downloaded content)
- Social networks (e.g. list of messages and interactions)
- E-commerce sites (e.g. address, telephone number)
- Opening and managing a bank account (e.g. telephone number, list of transactions completed)
- Online messaging services (e.g. phone number, recovery email address)

The Cnil Strongly recommends that an internal procedure be put in place to respond to requests that may be received. For example, provide a feature that allows the data subject to upload their data in a standard computer-readable format (CSV, XML, JSON, etc.) directly from their authenticated account/space.

The controller may **refuse the portability request** on condition that it gives reasons for its decision. It can also **failing to respond to manifestly abusive requests** in particular because of their number and their repetitive or systematic nature.

Right to object to processing

The controller must allow the data subject to **to oppose the re-use of his data** for the purpose of soliciting, in particular for commercial purposes, when placing an order or signing a contract.

A check box, not checked by default, must allow them to express their choice directly on the form or order form to be filled in. The mere mention of the existence of that right in the general conditions is not sufficient.

The right of opposition may be exercised by the person **only if** treatment is warranted by legitimate interest (https://www.cnil.fr/fr/les-bases-legales/interet-legitime) (e.g. processing for fraud prevention purposes or to ensure network and information security).

On the contrary, if the processing is justified because the data subject has given his or her consent, the data subject must exercise his or her right to withdraw consent and not his or her right to object.

Maintain a record of treatments

The register of processing activities allows **to identify data processing** and to have an overview of the uses of this personal data.

Who is affected by the register?

The obligation to keep a register of treatments does not apply to all companies, it is necessary to refer to their size.

Less than 250 employees

The keeping of the register shall be **obligatory** where the company carries out **any of the following** :

- Treatment **not occasional** (e.g. payroll management, customer/prospect and supplier management)
- Treatment that may involve a **risk to the rights and freedoms of individuals** (e.g. geolocation, video surveillance systems)
- Treatment of **sensitive data** or data relating to **criminal convictions**.

In case of doubt, the Cnil recommends that treatment be included in the registry.

From 250 employees

Where the company employs at least 250 employees, the keeping of a register of salaries shall be **obligatory**.

> **Please note**
>
> The **subcontractors** must also keep a record of their activities involving the processing of data.

What should the register contain?

The register shall **to identify all treatments** implemented by the company.

In practice, a record sheet must be established for each treatment. Each record sheet shall contain **next items** :

- Identity of controller, data protection officer and processors
- Categories of persons concerned (e.g. customer, prospect, employee)
- Categories of data processed (e.g. identity, family, economic or financial situation, banking data, connection data, location data)
- Purposes of the processing, i.e. the purpose for which the data were collected
- Recipients of the data, i.e. those to whom the data have been or will be communicated, including processors
- Duration of data retention, or failing this, the criteria for determining it
- General description of data security measures
- Where applicable, transfer of data to a country outside the EUEU.

What form should the register take?

The GDPR only requires that **the register shall be in written form**. The format of the register shall be free and may be in paper or electronic form.

The CNIL provides process register templates (https://www.cnil.fr/fr/RGPD-le-registre-des-activites-de-traitement) .

Ensuring the security of personal data

Any company shall **ensuring the security of personal data** collected (customer, supplier, employee data, etc.). To ensure a level of security appropriate to the risk, many **technical and organizational measures** are necessary.

FYI

The Cnil provides a practical guide (https://www.cnil.fr/sites/cnil/files/2024-03/cnil_guide_securite_personnelle_2024.pdf) on data security.

Census data processing

The controller shall **identify treatments** of personal data (automated or not) **and media** on which these treatments are based, namely:

- hardware (e.g. servers, laptops, hard drives)
- software (e.g. operating systems, business software)
- logical or physical communication channels (e.g. fiber optic, Wi-Fi, Internet, voice, couriers)
- paper media (e.g. printed documents, photocopies)
- physical premises and facilities where the above mentioned items are located (e.g. computer rooms, offices).

Assess the risks associated with each treatment

This census makes it possible**assess risks** generated by each treatment, including:

- **Illegitimate access to data** (e.g. impersonation following the disclosure of the pay slips of all employees of a company)
- **Unwanted modification of data** (e.g. wrongly accusing a person of misconduct or misdemeanor following modification of access logs)
- **Data Disappearance** (e.g. failure to detect a drug interaction due to inability to access the electronic patient record).

The controller shall identify the **sources of risk** considering human (e.g., IT administrator, user, external attacker, competitor) and non-human (e.g., water, outbreak, hazardous materials, non-target computer virus) sources.

It must also **estimate the severity and likelihood of the risks** (example of a scale that can be used for estimation: negligible, moderate, large, maximum) for this **to determine the measures** able to address each risk (e.g. access control, backups, traceability, premises security, encryption, anonymization).

Raise awareness among users

The controller shall **sensitize** the users on security and privacy issues. This can be done by organizing an awareness session, sending regular updates on relevant procedures for people according to their duties, sending reminders via e-mail, etc.

The manager must **document operating procedures,** keep them up to date and make them available to all concerned users. Specifically, any action on the processing of personal data, whether it is an administration operation or the simple use of an application, must be explained in clear language and adapted to each category of users, in documents to which the latter may refer.

In addition, he must **write an it charter**, annexed to rules and regulations (https://entreprendre.service-public.gouv.fr/vosdroits/F1905?lang=en) , including the following information:

- Data protection rules and penalties for non-compliance
- Scope of the Charter (e.g. how data management teams are involved, means of authentication, security rules)
- How to use the computer resources made available (workstation, storage space, Internet access, e-mail, etc.)
- Conditions for the administration of the information system
- Liabilities and penalties for non-compliance with the Charter.

Please note

It may be appropriate to provide for the signature of a **confidentiality commitment**, or to include in employment contracts a specific confidentiality clause concerning personal data. One **model** confidentiality commitments shall be made available by the Council.

Data Privacy Engagement Template

Business Business I, the undersigned Mr./Mrs.
_____
_____
_____

recognize the confidentiality of such data.

I therefore undertake, in accordance with Article 32 of the General Data Protection Regulation of 27 April 2016, to take all precautions in accordance with the state of the art and internal rules within the framework of my duties

in order to protect the confidentiality of the information to which I have access, and in particular to prevent it from being communicated to persons not expressly authorized to receive that information.

In particular, I commit to:

- not use the data I can access for purposes other than those provided for by my powers;
- disclose such data only to persons duly authorized by reason of their duties to receive such data, whether private, public, natural or legal persons;
- make no copies of such data except as necessary for the performance of my duties;
- take all measures in accordance with the state of the art and internal rules within the framework of my powers to prevent the misuse or fraudulent use of this data;
- take all precautions in accordance with the state of the art and internal rules to safeguard the physical and logical security of such data;
- ensure, within the limits of my powers, that only secure means of communication will be used to transfer such data;
- in the event of termination of my duties, return in full the data, computer files and any information medium relating to these data.

This undertaking of confidentiality, in force throughout my term of office, will remain effective, without limitation, after I have ceased to hold office, whatever the cause, provided that this undertaking concerns use

and the provision of personal data.

I have been informed that any violation of this undertaking will subject me to disciplinary and criminal sanctions in accordance with the regulations in force, in particular with regard to Articles 226-13 and 226-16 to 226-24 of the Criminal Code.

Done at _____, on dd/mm/yyyy, in X copies

Name:

Signature:

Authenticate users

To ensure that a user only has access to the data they need, they must have a **unique identifier** and must **authenticate** before any use of the computer means.

An essential precaution is to **define a unique identifier per user** and prohibit accounts shared between multiple users. Where the use of generic or shared identifiers is unavoidable, the following measures shall be implemented:

- Require hierarchy validation
- Implement means to trace actions associated with these identifiers
- Renew the password as soon as a person no longer needs to access the account.

> **Please note**
>
> If you are using password-based user authentication, it is recommended that you follow the recommendations of the Council (https://www.cnil.fr/fr/mots-de-passe-une-nouvelle-recommandation-pour-maitriser-sa-securite) .

Manage User Entitlement

The controller shall **manage user entitlement** in order to limit their access to the only data they need for the performance of their tasks.

The person responsible is first brought to **define entitlement profiles** in systems by separating tasks and areas of responsibility; and **to have any application for authorization validated** by a manager (e.g. supervisor, project manager).

It is imperative to **remove access permissions** users as soon as they are no longer entitled to access a premises or an IT resource (e.g. change of mission or post), as well as at the end of their contract.

> **Please note**

> It is recommended to **conduct a regular review of entitlements** (at least annually) to identify and remove unused accounts and realign the rights granted to the functions of each user.

Trace Operations

The controller shall also **trace operations** to be able to respond to data breaches (breaches of confidentiality, integrity or availability).

To do this, it is necessary to put in place **a logging system**, which is a record of users' business activities, technical interventions (including by administrators), anomalies, and security events.

The controller shall ensure that the records managers notify the controller of any security anomaly or incident as soon as possible.

> **Please note**
>
> L'So provides a best practice guide (https://cyber.gouv.fr/publications/recommandations-de-securite-pour-larchitecture-dun-systeme-de-journalisation) to establish an efficient and secure logging system.

Secure desktops and mobile computing

The risks of intrusion into computer systems are significant. The controller shall **protect workstations** which are one of the main points of entry.

In order to prevent fraudulent access, virus execution or remote malicious takeovers, the controller must take the necessary **following precautions** :

- Provide a mechanism for **automatic session locking** if the station is not used for a given time
- SETTLE a **"firewall"** ("firewall") software on the workstation and limit the opening of the communication ports to those strictly necessary for the proper functioning of the applications settled on the workstation
- Use **anti-virus regularly updated** and provide for a policy of **regular software updates**
- Securely erase data on a computer **before reassignment** to another person.

> **Please note**
>
> The Government Center for Computer Attack Watch, Warning and Response (CERT-FR) details the good reflexes to adopt in case of intrusion (https://www.cert.ssi.gouv.fr/les-bons-reflexes-en-cas-dintrusion-sur-un-systeme-dinformation/) on an information system.

Off-premises work practices (e.g. traveling, teleworking) involve specific risks related to the use of laptops, USB sticks or smartphones. It is therefore essential to anticipate the data breach **outside the premises**.

The controller shall **to raise awareness among users** specific risks associated with the use of mobile computing tools (e.g. theft of equipment, risks associated with connection to public networks) and **mandate the use of VPN** Strong authentication.

It is also recommended to **providing encryption means** Mobile PCs and mobile storage media (e.g. laptop, USB drives, external hard drive, CD-R, DVD-RW), such as:

- Hard Drive Encryption (many operating systems include such functionality)
- File-by-file encryption
- Creating encrypted containers (a file that may contain multiple files).

> **Please note**
>
> The CNIL recalls the key principles of cryptology (https://www.cnil.fr/fr/comprendre-les-grands-principes-de-la-cryptologie-et-du-chiffrement) (encryption, hash, signature).

Back up and archive data

The controller shall **perform regular backups** to minimize the impact of data loss or unwanted alteration. It is also recommended to store at least one **backup to an external site** and isolate a **offline backup**, disconnected from the company's network.

In addition, the person responsible must **archive data that is no longer in daily use** but which have not yet reached their shelf-life, for example because they are stored for use in case of dispute.

To do this, it must define an archive management process that calls for several questions, including:

- What data needs to be archived?
- How and where are they stored?
- What are the specific ways to access archived data? (use of an archive should be done on an ad hoc and exceptional basis)
- With regard to the destruction of archives, what method of operation should be chosen to ensure that an entire archive has been destroyed?

> **Please note**
>
> The CNIL has established a list of recommendations (https://www.legifrance.gouv.fr/cnil/id/CNILTEXT000017651957/) concerning the arrangements for electronic archiving.

Manage Outsourcing

Data processing carried out by a processor on behalf of the controller must be subject to adequate safeguards, in particular with regard to security.

It is imperative to use only **sub-contractors providing sufficient guarantees**, particularly in terms of expertise, reliability and resources. The controller shall require the provider to communicate its information systems security policy and any certifications.

A subcontract must define the subject matter, duration, purpose of the processing and the obligations of the parties, in particular in terms of security of processing. It shall contain provisions laying down the following:

- Division of responsibilities and obligations in relation to **confidentiality of personal data** entrusted
- **Minimum authentication requirements** of users
- **Conditions for the return and destruction of data** at the end of the contract
- **Incident Management and Notification Rules**. This should include information to the controller in the event of a security breach or security incident.

> **Please note**
>
> The CNIL published a guide to accompany subcontractors (https://www.cnil.fr/sites/cnil/files/atoms/files/rgpd-guide_sous-traitant-cnil.pdf) in the practical implementation of their obligations.

Assess data security

Since there are many measures to ensure data security, it is appropriate to**assess the level of security of personal data** company. The CNIL provides a evaluation grid (https://www.cnil.fr/sites/cnil/files/2023-08/guide_securite_donnees_personnelles-checklist.pdf) .

The technical and organizational measures implemented by the controller must be **appropriate**, taking into account the nature, scope, context and purposes of the processing and the risks (the degree of probability and seriousness of which varies) to the rights and freedoms of individuals.

In the event of a data breach (e.g. unauthorized disclosure, irregular access), the controller must be **able to prove** that it has taken adequate security measures.

Supervising subcontracting

The controller may **to use a subcontractor** responsible for processing personal data on its behalf.

This may be an IT service provider (e.g. hosting, maintenance), an IT security company or even a marketing or communication agency processing personal data on behalf of the controller.

In order to manage their relationship, the controller and its processor must conclude a **subcontract**.

What information should be included in the contract?

The controller and the processor shall enter into a contract including **following mandatory particulars** :

- Purpose of the contract, i.e. the activity of the subcontractor (e.g. data hosting, email routing, maintenance)

- Nature, purpose and duration of processing
- Type of personal data collected and categories of data subjects
- Obligations and rights of the controller
- Obligations and rights of the subcontractor.

In order to facilitate the drafting of this contract, the parties may insert certain standard contractual clauses (CLC) (https://eur-lex.europa.eu/legal-content/FR/TXT/PDF/?uri=CELEX:32021D0915) drafted by the European Commission. They provide a useful support to frame subcontracting in accordance with the requirements of the GDPR.

> **Please note**
>
> Any processing operation not provided for in the contract must, in principle, be the subject of prior renegotiation between the parties or at least written instructions from the controller.

What are the obligations of the subcontractor?

The subcontractor must comply with the **subsequent obligations** :

- Ensure a sufficient level of security with regard to the nature of the data processed
- Advise the controller (e.g. alert the controller if he/she believes that an instruction he/she receives constitutes a violation of applicable regulations)
- Assist the controller in guaranteeing the rights of individuals (access, rectification, erasure, portability)
- Formalize instructions issued by the controller in writing
- Maintain a record of processing activities performed on behalf of the controller
- Keep available to the controller all information necessary to demonstrate compliance and enable audits to be carried out
- Ensure that persons authorized to process personal data undertake to respect confidentiality.

Register kept by the subcontractor

The subcontractor shall **keep its own register**, listing all categories of processing activity carried out on behalf of its clients (e.g. data hosting, IT maintenance, marketing message sending service).

In practice, a record sheet must be established for each of these categories of activities. Each record sheet shall contain **next items** :

- Identity of the processor, of its representative in the case of an establishment outside the EU, of its data protection officer and of the processors to whom it has recourse
- Categories of processing carried out on behalf of each of its clients, i.e. the operations actually carried out on their behalf. For example, for the category " *prospecting message service* , such as collecting email addresses, sending messages securely, managing unsubscriptions, and so on.)
- General description of data security measures
- Where applicable, transfer of data to a country outside the EUEU.

> **Please note**
>
> The CNIL provides a practical guide (https://www.cnil.fr/sites/cnil/files/atoms/files/rgpd-guide_sous-traitant-cnil.pdf) to subcontractors.

Can the subcontractor itself use a subcontractor?

The subcontractor shall **obtain written authorization** the controller before recruiting another processor. This authorization may be given to the subcontractor **on a case by case basis** for each new subcontractor, or have a **general scope**.

The CNIL recommends specifying in the contract which of these 2 authorization procedures is chosen by the parties.

If the authorization is of general application, the processor shall communicate to the controller of the **list of its subsequent subcontractors**and any additions or substitutions to that list to enable it to object if it so wishes. In this case, the Council recommends formalizing the procedures for informing the controller and, possibly, the criteria for selecting these subcontractors.

> **Please note**
>
> The subcontractor shall keep an up-to-date list of subcontractors in its register.

Appoint a Data Protection Officer (DPO)

Companies carrying out large-scale data processing shall designate a **data protection officer**, most commonly called " *data protection officer (DPO)'* in English. The DPO is responsible for**to ensure the protection of personal data** collected and processed by the employing company.

> **Please note**
>
> The CNIL provides a DPO Practical Guide (https://www.cnil.fr/sites/cnil/files/atoms/files/guide_pratique_rgpd_-_delegues_a_la_protection_des_donnees.pdf) .

Is the designation of a DPO mandatory?

The designation of a DPO by the company is **obligatory** in **the following 2 cases** :

- The main activities of the company or subcontractor involve a **regular and systematic large-scale monitoring** data subjects involved in processing operations (e.g. geolocation, video surveillance, banking processing).
- The main activities of the company or subcontractor involve a **large-scale treatment of sensitive data** or relating to criminal convictions.

The concept of treatment **large-scale** shall be analyzed on a case-by-case basis, depending on the number of data subjects involved, the volume and range of different data collected, the duration of the processing activity and the geographical distribution of the processing activity.

Example :

Some examples of large-scale treatments include:

- the processing for statistical purposes of current location data of customers of an international fast food chain by a processor specialized in such services
- the processing of customer data in the course of the day-to-day business of an insurance company or a bank
- the processing of personal data by a search engine for the display of advertisements based on browsing behavior
- the processing of personal data (content, data flows, location) by telephony and Internet service providers.

Conversely, examples of treatments that are not considered large-scale treatments:

- the treatment of patient data by an independent physician
- the processing of personal data relating to convictions by a lawyer.

> **Please note**
>
> Apart from cases of mandatory designation, the appointment of a Data Protection Officer shall be **encouraged**.

What are the DPO's missions?

The duties of the Data Protection Officer shall be as follows:

- **Inform and advise** the controller or processor and the employees who carry out the processing on the obligations incumbent upon them
- **Check** compliance with the GDPR and the internal data protection rules of the controller or processor, including the allocation of responsibilities, awareness raising and training of personnel involved in processing operations
- **Provide advice and recommendations**, upon request, on a specific subject related to the processing of personal data
- **Cooperate with the Cnil** and act as a point of contact on treatment issues.

> **Please note**
>
> The Data Protection Officer shall be subject to a **duty of confidentiality** with regard to the performance of its tasks.

How to choose and designate the DPO?

The Data Controller may designate a DPO **internally** or a **external provider** offering its DPO services. He must ensure that the DPO has **specialist knowledge** data protection law and practice. They must take into account the training received by the person involved, as well as their **experience** and his knowledge of the sector.

The Cnil has implemented a **certification procedure** the powers of the DPO. The procedure is not **not obligatory** but allows the DPO who followed him to justify that he meets the competency requirements. The certifications are issued by certifying bodies approved by the CNIL.

> **Please note**
>
> To verify that a DPO is truly certified, the controller can contact the certifying organization. The CNIL publishes a list of approved certification bodies (https://www.cnil.fr/fr/organisme-agrees) .

When selecting the company's DPO, the controller must complete the **online designation form** to inform the CNIL.

Appointment of a Data Protection Officer (DPO) (https://entreprendre.service-public.gouv.fr/vosdroits/R12144)

What are the conditions for performing the OPD function?

The controller shall allow the DPO to exercise its supervisory, advisory and contact functions **in complete independence**. Independence must be guaranteed in the following way:

- The DPO shall not be in a conflict of interest situation if his function as DPO is combined with another function. For example, there is a conflict of interest when the DPO is entrusted with tasks in which he determines the purposes and means of processing.
- The DPO must be accountable to the highest level of company management
- The DPO shall not be sanctioned for the performance of its DPO duties
- The DPO shall not be instructed in the performance of his or her DPO duties.

In addition, the DPO must have sufficient time and **adequate material and human resources** to carry out its mission. It must have the active support of management and be **associated upstream to all projects** involving personal data.

> **Please note**
>
> The DPO may act as a delegate **part-time**, in addition to other activities for the organization (internal) or for other clients (external).

What is the risk for a company that does not designate a DPO?

A company that does not designate an OPD where such designation is mandatory shall be subject to **Cnil sanctions** :

- Call to Order
- Injunction to comply
- Administrative fine up to **€10 million** or **2% of annual turnover** of the preceding financial year, whichever is the greater.

Carry out an impact assessment

To ensure that its treatment complies with the GDPR, the company may need to carry out a **Data Protection Impact Assessment (DPIA)**. This procedure makes it possible to assess both the risks involved and the way in which they can be controlled.

Is impact assessment mandatory?

The carrying out of an impact assessment is **obligatory** when the data processing presents a **high risk to rights and freedoms** the persons concerned, namely:

- Either the treatment is listed in the list of treatments (https://www.cnil.fr/sites/cnil/files/atoms/files/liste-traitements-aipd-requise.pdf) for which the CNIL considered it mandatory to carry out an impact assessment.
- Either the treatment fulfills at least **2 of the following criteria** :
  - evaluation/scoring (including profiling)
  - automatic decision with legal or similar effect
  - systematic surveillance
  - collection of sensitive data
  - large-scale collection of personal data
  - data crossing
  - vulnerable people (patients, elderly, children, etc.)
  - innovative use (use of new technology)

- exclusion from entitlement to a right/contract.

Example :

One company is implementing ad processing to collect geolocation data from millions of individuals to create ad profiles and display targeted advertising based on their travel patterns.

This processing fulfills the criteria of large-scale collection and the collection of sensitive data (location data). Thus, the implementation of an AIPD will be necessary.

The AIPD must be conducted **before treatment is started**. It should be started as early as possible and will be updated throughout the treatment life cycle.

What should the impact assessment contain?

The impact assessment must contain at least **following information** :

- **Description** system of **processing operations** envisaged and the **purposes** processing, including, where appropriate, the legitimate interest pursued by the controller
- **Assessment of necessity** and the **proportionality** processing operations with regard to the purposes
- **Risk Assessment** on the rights and freedoms of data subjects
- **Measures envisaged** to address risks, including safeguards, measures and security mechanisms to ensure the protection of personal data and to demonstrate compliance with the Regulation.

> **Please note**
>
> The Cnil provides guides to good practice (https://www.cnil.fr/fr/guides-aipd) and a free software (https://www.cnil.fr/fr/outil-pia-telechargez-et-installez-le-logiciel-de-la-cnil) to facilitate an impact assessment.

The controller should then **forward the impact assessment to the Council** through the following online service:

Submit a Data Protection Impact Assessment (DPIA) to the CNIL (https://entreprendre.service-public.gouv.fr/vosdroits/R67638)

What sanctions should be imposed in the absence of an impact assessment?

A company that does not carry out an impact assessment is exposed to **Cnil sanctions** :

- Call to Order
- Injunction to comply
- Administrative fine up to **€10 million** or **2% of annual turnover** of the preceding financial year, whichever is the greater.

Protect data in the event of transfer outside the EU

The transfer of data outside the EU is when a company sends personal data it has collected **to a non-EU countryEU (EU)**.

In most cases, a transfer of data outside the EU takes place within **2 subsequent cases** :

- **The company has recourse to a subcontractor established outside the EU** (e.g. a US-based data hosting company)
- **Companies in the same group exchange data** (e.g. the French subsidiary sends the personal data of its employees to the headquarters of the group in Japan).

Under what conditions can data be transferred outside the EU?

In order for a transfer of data outside the EU to be authorized, the country receiving the data must be subject to a **adequacy decision**.

This is a decision adopted by the European Commission establishing that a third country presents a **adequate level of protection** personal data. The Commission assesses this level of protection on the basis of elements set out in the GDPR (e.g. the country's domestic legislation, the existence of an independent data protection supervisory authority and the country's international commitments).

The adequacy decision shall have the effect of enabling the transfer of data to the country concerned, **without additional requirements**.

> **Please note**

> Data transfer is **free**, for example, to the United Kingdom, Japan, Argentina, South Korea, or the United States (to certified US entities). The list of suitable countries (https://www.cnil.fr/fr/la-protection-des-donnees-dans-le-monde) is accessible on the CNIL website.

In the absence of an adequacy decision, the controller shall implement **appropriate safeguards** before transferring the data outside the EU. These may include:

- Entering into a contract including standard contractual clauses (CLC) (https://eur-lex.europa.eu/legal-content/FR/TXT/PDF/?uri=CELEX:32021D0914) of the European Commission. These clauses provide a useful framework for transfer outside the EU, in line with the requirements of the GDPR.
- Establish **binding company rules** (*Binding Corporate Rules (BCR)* in English). For multinational companies with large data transfers, these rules refer to an intra-group data protection policy that unifies safeguards for the processing of personal data offered by their subsidiaries worldwide.
- Join a **code of conduct**. The Code is a tool set up by an organization representing a sector of activity. It highlights good practices in the sector, such as standard information notices, model contractual clauses or recommendations for security measures, in a vocabulary adapted to the sector. The Code is legally binding on its members.

> **Please note**
>
> If there is a risk that these safeguards will not be effective, the data exporter should put in place additional measures to ensure the effectiveness of the safeguards.

What derogations allow data to be transferred outside the EU?

In the absence of an adequacy decision or appropriate safeguards, the transfer may be carried out **by way of derogation**, in special situations:

- The data subject has given his or her consent **consent explicit** the intended transfer, **after having been informed of the risks that such a transfer might entail for it**
- The transfer is **necessary for the performance of a contract** between the data subject and the controller or to implement pre-contractual measures taken at his request
- The transfer is **necessary for the conclusion or performance of a contract concluded in the interest of the data subject** between the controller and another natural or legal person
- Transfer is required for **important grounds of public interest**
- The transfer is necessary to **the establishment, exercise or defense of legal claims**
- The transfer is **necessary to safeguard the vital interests of the data subject or other persons**, where the data subject is physically or legally unable to give consent
- The transfer takes place **from a register** which is legally intended to provide information to the public and is open to consultation by the public or any person having a legitimate interest.

Transfer outside the EU where no particular situation applies

Where none of these situations applies, a transfer to a third country is still allowed **if the following conditions are met** :

- The transfer shall not be repetitive and shall affect only a limited number of persons concerned
- The transfer is necessary for the purposes of the legitimate interests pursued by the controller over which the interests or rights and freedoms of the data subject do not prevail
- The controller has assessed all the circumstances surrounding the transfer of data and has offered, on the basis of that assessment, appropriate safeguards with regard to the protection of personal data.

Statute and miscellaneous references

Regulation (EU) 2016/679 of 27 April 2016 - protection of individuals with regard to the processing of personal data (GDPR) (https://eur-lex.europa.eu/legal-content/FR/TXT/PDF/?uri=CELEX:32016R0679?lang=en)
Law n°2018-493 of 20 June 2018 on the protection of personal data (https://www.legifrance.gouv.fr/loda/id/JORFTEXT000037085952?lang=en)
Consumer Code: Articles L224-42-1 to L224-42-4 (https://www.legifrance.gouv.fr/codes/id/LEGISCTA000033206899/2018-05-25/?lang=en)
Data recovery and portability
Penal Code: Articles 226-16 to 226-24 (https://www.legifrance.gouv.fr/codes/id/LEGISCTA000006165313?lang=en)
Criminal sanctions

Online services and forms

Appointment of a Data Protection Officer (DPO) (https://entreprendre.service-public.gouv.fr/vosdroits/R12144?lang=en)
Online service

Submit a Data Protection Impact Assessment (DPIA) to the CNIL (https://entreprendre.service-public.gouv.fr/vosdroits/R67638?lang=en)
Online service

Free online training (GDPR - Atelier Mooc) (https://entreprendre.service-public.gouv.fr/vosdroits/R67688?lang=en)
Online service

Additional topics

GDPR Guide for Small companies (https://www.edpb.europa.eu/sme-data-protection-guide/home_fr?lang=en)
European Data Protection Board (EDPS)

Examples of information (GDPR) (https://www.cnil.fr/fr/rgpd-exemples-de-mentions-dinformation?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Practical Guide to Securing Data (https://www.cnil.fr/sites/cnil/files/2024-03/cnil_guide_securite_personnelle_2024.pdf?lang=en)
National Commission for Informatics and Freedoms (Cnil)

How to base a treatment on legitimate interest? (https://www.cnil.fr/fr/les-bases-legales/interet-legitime?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Data processing register templates (https://www.cnil.fr/fr/RGPD-le-registre-des-activites-de-traitement?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Password authentication (CNIL recommendations) (https://www.cnil.fr/fr/mots-de-passe-une-nouvelle-recommandation-pour-maitriser-sa-securite?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Logging system (ANSSI recommendations) (https://cyber.gouv.fr/publications/recommandations-de-securite-pour-larchitecture-dun-systeme-de-journalisation?lang=en)
National Agency for Information Systems Security (Anssi)

The right reflexes in case of intrusion on an information system (https://www.cert.ssi.gouv.fr/les-bons-reflexes-en-cas-dintrusion-sur-un-systeme-dinformation/?lang=en)
Government Computer Attack Watch, Warning and Response Center (CERT-FR)

Electronic archiving procedures (CNIL recommendations) (https://www.legifrance.gouv.fr/cnil/id/CNILTEXT000017651957/?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Personal Data Security Assessment Grid (https://www.cnil.fr/sites/cnil/files/2023-08/guide_securite_donnees_personnelles-checklist.pdf?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Subcontractor Guide (GDPR) (https://www.cnil.fr/sites/cnil/files/atoms/files/rgpd-guide_sous-traitant-cnil.pdf?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Standard contractual clauses (subcontracting and GDPR) (https://eur-lex.europa.eu/legal-content/FR/TXT/PDF/?uri=CELEX:32021D0915?lang=en)
European Commission

DPO Practical Guide (https://www.cnil.fr/sites/cnil/files/atoms/files/guide_pratique_rgpd_-_delegues_a_la_protection_des_donnees.pdf?lang=en)
National Commission for Informatics and Freedoms (Cnil)

List of treatments for which an impact assessment is required (https://www.cnil.fr/sites/cnil/files/atoms/files/liste-traitements-aipd-requise.pdf?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Conduct an impact assessment - Practical guides (https://www.cnil.fr/fr/guides-aipd?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Downloadable PIA tool: Facilitating impact assessments (https://www.cnil.fr/fr/outil-pia-telechargez-et-installez-le-logiciel-de-la-cnil?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Countries suitable for data transfer outside the EU (GDPR) (https://www.cnil.fr/fr/la-protection-des-donnees-dans-le-monde?lang=en)
National Commission for Informatics and Freedoms (Cnil)

Standard contractual clauses (transfer of data outside the EU) (https://eur-lex.europa.eu/legal-content/FR/TXT/PDF/?uri=CELEX:32021D0914?lang=en)
European Commission

Client file and GDPR compliance (https://www.francenum.gouv.fr/guides-et-conseils/developpement-commercial/gestion-des-donnees-clients/comment-rendre-le-fichier?lang=en)
France Num

Rules for biometric access control in the workplace
(https://www.cnil.fr/fr/le-controle-dacces-biometrique-sur-les-lieux-de-travail?lang=en)
National Commission for Informatics and Freedoms (Cnil)